

Jeremiah Grossman

Venture capitalist (Grossman Ventures <https://grossman.vc>), Internet protector and industry creator. Founded WhiteHat Security & Bit Discovery. BJJ Black Belt.

THURSDAY, DECEMBER 17, 2009

Attention security researchers! Submit your new 2009 Web Hacking Techniques



Update 01.04.2010: Voting process is commencing this week! Expert judges are Rich Mogull, Dinis Cruz, Chris Hoff, HD Moore, Billy Rios, Dan Kaminsky, Romain Gaucher, Steven Christey, Jeff Forristal, and Michal Zalewski.

Update: Awesome news, Black Hat is generously sponsoring the effort! The researcher topping the list will be awarded a free pass to attend the BlackHat USA Briefings 2010!

Just 2 weeks left in 2009. Time to start collecting all the latest published research in preparation for the coveted **Top Ten Web Hacking Techniques** list!

Every year Web security community produces dozens of new hacking techniques documented in white papers, blog posts, magazine articles, mailing list emails, etc. We are not talking about individual vulnerability instances with CVE numbers, nor intrusions / incidents, but the actual new methods of Web attack. Some target the website, some target the browser, or somewhere in between.

Historically many of these works would permanently reside in obscure and overlooked corners of the Web. Now it its fourth year the list provides a centralized reference point and recognizes researchers who have contributed to the advancement of our industry.

The top ten winners will be selected by a panel of judges (names to be announced soon) on the basis of novelty, potential impact, and overall pervasiveness. Those researchers topping the list can expect to receive praise amongst their peers as have those in past years (2006, 2007, 2008).

Then coming up at [IT-Defense](#) (Feb.) and [RSA USA 2010](#) (Mar.) it will be my great honor to introduce each of the top ten during my "2010: A Web Hacking Odyssey" presentations. Each technique will be described in technical detail for how they work, what they can do, who they affect, and how best to defend against them. Audiences get an opportunity to better understand the newest attacks believed most likely to be used against us in the future.

To make all this happen we are going to need a lot of help from the community. At the bottom of this post will be the living master list of everything published. If anything is missing, and we know for a fact there is, please comment containing the link to the research. We



BIO

Jeremiah Grossman brings 20+ years of experience in Computer Security and has become one of the most recognizable and world-renowned cybersecurity experts in the industry, coining several of the original hacking terms commonly used around the world today. Early in his career, Jeremiah was known as "The Hacker Yahoo" which led to his role as the company's Information Security Officer. Jeremiah founded WhiteHat Security (now Synopsis), and served as Chief of Security Strategy for SentinelOne which was the highest-valued cybersecurity IPO in history. Most recently, Jeremiah was the founder & CEO of Bit Discovery, which was acquired by Tenable in 2022. He also serves as a company advisor and board member to several tech startups. In his spare time, Jeremiah does Brazilian Jiu-Jitsu and is passionate about classic cars. He recently opened Toybox, a luxury car club in Boise, Idaho.

LINKS

[Jeremiah Grossman](#)

[Twitter](#)

[Facebook](#)

[LinkedIn](#)

[Grossman Ventures](#)

SUBSCRIBE

 Posts

 Comments

understand that while not every technique is as powerful as another, please make every effort to include them anyway, nothing should be considered too insignificant. You never know what method might be found useful another researcher down the road.

Thank you and good luck!

The Complete List

1. [Persistent Cookies and DNS Rebinding Redux](#)
2. [iPhone SSL Warning and Safari Phishing](#)
3. [RFC 1918 Blues](#)
4. [Slowloris HTTP DoS](#)
5. [CSRF And Ignoring Basic/Digest Auth](#)
6. [Hash Information Disclosure Via Collisions - The Hard Way](#)
7. [Socket Capable Browser Plugins Result In Transparent Proxy Abuse](#)
8. [XMLHttpRequest "Ping" Sweeping in Firefox 3.5+](#)
9. [Session Fixation Via DNS Rebinding](#)
10. [Quickly Firefox DoS](#)
11. [DNS Rebinding for Credential Brute Force](#)
12. [SMBEnum](#)
13. [DNS Rebinding for Scraping and Spamming](#)
14. [SMB Decloaking](#)
15. [De-cloaking in IE7.0 Via Windows Variables](#)
16. [itms Decloaking](#)
17. [Flash Origin Policy Issues](#)
18. [Cross-subdomain Cookie Attacks](#)
19. [HTTP Parameter Pollution \(HPP\)](#)
20. [How to use Google Analytics to DoS a client from some website.](#)
21. [Our Favorite XSS Filters and how to Attack them](#)
22. [Location based XSS attacks](#)
23. [PHPIDS bypass](#)
24. [I know what your friends did last summer](#)
25. [Detecting IE in 12 bytes](#)
26. [Detecting browsers javascript hacks](#)
27. [Inline UTF-7 E4X javascript hijacking](#)
28. [HTML5 XSS](#)
29. [Opera XSS vectors](#)
30. [New PHPIDS vector](#)
31. [Bypassing CSP for fun, no profit](#)
32. [Twitter misidentifying context](#)
33. [Ping pong obfuscation](#)
34. [HTML5 new XSS vectors](#)
35. [About CSS Attacks](#)
36. [Web pages Detecting Virtualized Browsers and other tricks](#)
37. [Results, Unicode Left/Right Pointing Double Angel Quotation Mark](#)
38. [Detecting Private Browsing Mode](#)
39. [Cross-domain search timing](#)
40. [Bonus Safari XXE \(only affecting Safari 4 Beta\)](#)
41. [Apple's Safari 4 also fixes cross-domain XML theft](#)
42. [Apple's Safari 4 fixes local file theft attack](#)
43. [A more plausible E4X attack](#)
44. [A brief description of how to become a CA](#)
45. [Creating a rogue CA certificate](#)
46. [Browser scheme/slash quirks](#)

47. Cross-protocol XSS with non-standard service ports
48. Forget sidejacking, clickjacking, and carjacking: enter "Formjacking"
49. MD5 extension attack
50. Attack - PDF Silent HTTP Form Repurposing Attacks
51. XSS Relocation Attacks through Word Hyperlinking
52. Hacking CSRF Tokens using CSS History Hack
53. Hijacking Opera's Native Page using malicious RSS payloads
54. Millions of PDF invisibly embedded with your internal disk paths
55. Exploiting IE8 UTF-7 XSS Vulnerability using Local Redirection
56. Pwning Opera Unite with Inferno's Eleven
57. Using Blended Browser Threats involving Chrome to steal files on your computer
58. Bypassing OWASP ESAPI XSS Protection inside Javascript
59. Hijacking Safari 4 Top Sites with Phish Bombs
60. Yahoo Babelfish - Possible Frame Injection Attack - Design Stringency
61. Gmail - Google Docs Cookie Hijacking through PDF Repurposing & PDF
62. IE8 Link Spoofing - Broken Status Bar Integrity
63. Blind SQL Injection: Inference through Underflow exception
64. Exploiting Unexploitable XSS
65. Clickjacking & OAuth
66. Google Translate - Google User Content - File Uploading Cross - XSS and Design Stringency - A Talk
67. Active Man in the Middle Attacks
68. Cross-Site Identification (XSid)
69. Microsoft IIS with Metasploit evil.asp;.jpg
70. MSWord Scripting Object XSS Payload Execution Bug and Random CLSID Stringency
71. Generic cross-browser cross-domain theft
72. Popup & Focus URL Hijacking
73. Advanced SQL injection to operating system full control (whitepaper)
74. Expanding the control over the operating system from the database
75. HTML+TIME XSS attacks
76. Enumerating logins via Abuse of Functionality vulnerabilities
77. Hellfire for redirectors
78. DoS attacks via Abuse of Functionality vulnerabilities
79. URL Spoofing vulnerability in bots of search engines (#2)
80. URL Hiding - new method of URL Spoofing attacks
81. Exploiting Facebook Application XSS Holes to Make API Requests
82. Unauthorized TinyURL URL Enumeration Vulnerability

Posted by Jeremiah Grossman at [3:37 PM](#)

36 comments:

Anonymous said...

MD5 extension attack for sure!
<http://netifera.com/research>

A lot of sites ARE STILL affected (some BIG)

December 17, 2009 at 5:16 PM

Anonymous said...

Attack - PDF Silent HTTP Form Repurposing Attacks

http://www.secniche.org/papers/SNS_09_03_PDF_Silent_Form_Re_Purp_Attack.pdf

December 17, 2009 at 8:04 PM

Anonymous said...

XSS Relocation Attacks through Word Hyperlinking

http://www.secniche.org/papers/SNS_09_01_Evad_Xss_Filter_Msword.pdf

December 17, 2009 at 8:14 PM

Jeremiah Grossman said...



Thanks all, added (49, 50, 51)

December 18, 2009 at 7:59 AM

Inferno said...



Hi Jeremiah,

Here are some of my contributions-

<http://securethoughts.com/2009/07/hacking-csrf-tokens-using-css-history-hack/>

<http://securethoughts.com/2009/08/hijacking-safari-4-top-sites-with-phish-bombs/>

<http://securethoughts.com/2009/08/bypassing-owasp-esapi-xss-protection-inside-javascript/>

<http://securethoughts.com/2009/11/using-blended-browser-threats-involving-chrome-to-steal-files-on-your-computer/>

<http://securethoughts.com/2009/08/pwning-opera-unite-with-infernos-eleven/>

<http://securethoughts.com/2009/05/exploiting-ie8-utf-7-xss-vulnerability-using-local-redirection/>

<http://securethoughts.com/2009/11/millions-of-pdf-invisibly-embedded-with-your-internal-disk-paths/>

<http://securethoughts.com/2009/10/hijacking-operas-native-page-using-malicious-rss-payloads/>

<http://securethoughts.com/2009/07/rsnakes-javascript-ping-sweep-attack-extended-for-internet-explorer-8/>

<http://securethoughts.com/2009/02/authorized-tinyurl-url-enumeration-vulnerability/>

Regards,
Inferno

December 18, 2009 at 9:32 PM

Jeremiah Grossman said...



Thanks Inferno, added all except one. (#52 - # 59)

December 19, 2009 at 8:06 AM

Aditya K Sood said...



Hi Jer

Yahoo Babelfish - Possible Frame Injection Attack - Design Stringency

<http://zeroknock.blogspot.com/2009/12/yahoo-babelfish-possible-inline-iframe.html>

December 19, 2009 at 9:43 AM

Anonymous said...

Gmail - Google Docs Cookie Hijacking through PDF Repurposing

http://secniche.org/gmd_hijack/gc_hijack.xhtml

http://secniche.org/gmd_hijack/advisory_gmail_google_docs_pdf_repurposing_attack.pdf

December 19, 2009 at 9:45 AM

Anonymous said...

IE8 Link Spoofing - Broken Status Bar Integrity

http://secniche.org/ie_spoof_myth/

December 19, 2009 at 10:04 AM

Jeremiah Grossman said...



@oknock, added #60

@anonymous, added #61 / #62

December 21, 2009 at 7:32 AM

belch said...



Blind SQL Injection: Inference through Underflow exception

<http://dbellucci.blogspot.com/2009/12/blind-sql-injection-inference-through.html>

December 21, 2009 at 10:05 AM

Jeremiah Grossman said...



@belch, thank you. #63

December 21, 2009 at 10:45 AM

Stephen Sciafani said...

<http://stephensciafani.com/2009/05/26/exploiting-unexploitable-xss/>

<http://stephensciafani.com/2009/05/04/clickjacking-oauth/>

December 21, 2009 at 6:16 PM

Jeremiah Grossman said...



@Stephen, thank you. Added #64 and #65

December 22, 2009 at 9:25 AM

Amish Shah said...

"iPhone SSL Warning and Safari Phishing" attack points to 404 page.

The correct hyper link would be,

<http://hackers.org/blog/20090329/iphone-ssl-warning-and-safari-phishing/>

December 23, 2009 at 4:25 AM

Jeremiah Grossman said...



@Amish, thanks fixed.

December 23, 2009 at 8:49 AM

Adi said...



This new type of attack is generic , will work on any system/OS/browser, doesn't relate to any implementation bug, and shows how can hackers penetrate VPN or even disconnected networks

Active Man in the Middle Attacks:
<http://blog.watchfire.com/wfblog/2009/02/active-man-in-the-middle-attacks.html>

Happy holiday season,
Adi

December 24, 2009 at 10:18 PM

Aditya K Sood said...



Google Translate - Google User Content - File Uploading Cross - XSS and Design Stringency - A Talk

<http://zeroknock.blogspot.com/2009/12/google-translate-google-user-content.html>

December 24, 2009 at 10:19 PM

Adi said...



Hi Jeremiah,

This new type of attack is generic , will work on any system/OS/browser, doesn't rely on any implementation bug, and shows how can hackers penetrate VPN or even closed networks.

Active Man in the Middle Attacks:
<http://blog.watchfire.com/wfblog/2009/02/active-man-in-the-middle-attacks.html>

Happy holiday season,
Adi

December 24, 2009 at 10:20 PM

MustLive said...



Jeremiah!

List of 2009 Web Hacking Techniques is a good thing (as it were with previous lists for 2007 and 2008).

Soon I'll write you about my 2009's web hacking techniques.

P.S.

Happy holidays to everyone.

December 26, 2009 at 1:47 PM

MustLive said...



Current list is interesting, but I must note about some of its items.

There are contributions by other researchers which is just the same as my own, but I did my own months and even years earlier :-). Like oknock's one about Yahoo Babelfish (which mentioned as #60). And also new oknock's comment about Google Translate.

I wrote about this hole in Yahoo Babelfish (on both babelfish.altavista.com and babelfish.yahoo.com) in beginning of 2009 (and found hole at 25.04.2008 and informed Yahoo which ignored to fix it).

About such XSS attacks which I called Remote XSS/HTML Include (and fun guys called it Frame Injection) I wrote many times at my site for last three years.

Like vulnerabilities at images.google.com (in 2007), images.search.yahoo.com (in 2008) and www.google.com and translate.google.com (in 2008) and at many other sites. And in all cases web site owners ignored to fix the holes.

So I recommend oknock to not touch my holes (which I found a long time before him) and find others (new ones) for himself :-). I very often see such cases, when other people found my holes after months and years after me :-). There was such case with hole in images.google.com, and here are cases with Yahoo Babelfish and Google Translate. Anyway I wish everyone Merry Christmas and Happy New Year!

December 26, 2009 at 2:05 PM

Ronen Zilberman said...



A new type of attack allowing cross-site identification using out of context information from social networks.

<http://blog.quaji.com/2009/12/out-of-context-information-disclosure.html>

December 27, 2009 at 12:18 PM

Jeremiah Grossman said...



@oknock, added #66. And please have a look at MustLive's work he cited. It does appear to look similar, but if not, would be helpful to know why. Either way, researchers including myself do cross paths with the work of others without knowing it.

@adi, added #67 - thank you.

@ronen, added #68 thanks.

December 28, 2009 at 8:05 AM

Aditya K Sood said...



Jer

There is no point of cross path as such. Primarily it is hard for a researcher to visit every blog or vice versa. It may be result as a same thing but the attack end points and explanation could vary depending to the disclosure done to the requisite vendor and their response.

December 28, 2009 at 8:45 AM

Jeremiah Grossman said...



@oknock understood, which is a big reason why I've been making such lists. To be a repository for reference if nothing else.

December 28, 2009 at 8:56 AM

Aditya K Sood said...



Jer

That's a great step. Another interesting discussion. Have a look:

<http://zeroknock.blogspot.com/2009/12/google-chrome-webkit-msword-scripting.html>

December 28, 2009 at 9:15 AM

Jeremiah Grossman said...



@oknock, added #70

December 28, 2009 at 3:57 PM

Inferno said...



Very cool cross-browser cross-domain css exploit by Chris Evans
<http://scarybeastsecurity.blogspot.com/2009/12/generic-cross-browser-cross-domain.html>

December 29, 2009 at 10:29 PM

Jeremiah Grossman said...



@Inferno, thanks added #70

December 30, 2009 at 8:36 AM

Anonymous said...

Research titled "Advanced SQL injection to operating system full control" [slides](#) and [whitepaper](#).

Research titled "Expanding the control over the operating system from the database" [slides](#)

It's by the same author of [sqlmap](#). The best in the field!

December 30, 2009 at 8:58 AM

.mario said...



I think we can add HTML+TIME XSS attacks working on all IEs from 5.5 to 8 like tweeted here:

<https://twitter.com/ox6D6172696F/status/7197250108>

<https://twitter.com/ox6D6172696F/status/7196350903>

<https://twitter.com/ox6D6172696F/status/7196312532>

<https://twitter.com/ox6D6172696F/status/7180793115>

Introduces loads of new possible vectors mostly unknown by devs and not filtered by common WAF/filter solutions.

December 30, 2009 at 9:02 AM

Avi Douglén said...

Hey Jeremiah,
Just a heads up wrt #68, the name was changed to Cross-Site Identification (or XSId, of course :)).

I think this name much better reflects the real impact of the issue.

A.D.

December 30, 2009 at 1:19 PM

Jeremiah Grossman said...



@Avi - updated.

December 30, 2009 at 1:35 PM

MustLive said...



Jeremiah!

Yesterday I wrote you a new letter (in addition to my first letter) with other my 2009's researches.

And also with mentioning of Soroush Dalili's research on IIS, which you also can look at. As I see you already mentioned it in #69 (you can add a link to pdf with advisory too).

January 2, 2010 at 2:04 PM

avivra said...



My contribution:

* Cross-Web2.o Scripting

<http://aviv.raffon.net/2009/05/18/CrossWeb2oScripting.aspx>

* Month of Twitter Bugs

<http://aviv.raffon.net/2009/06/15/MonthOfTwitterBugs.aspx>

<http://www.twitpwn.com>

* Flash Shared Object - Bypass "Private Browsing" mode

<http://aviv.raffon.net/2009/08/17/NotSoPrivateAfterAll.aspx>

January 3, 2010 at 5:26 AM

acheter kamagra said...

Il n'ya pas de point de croix chemin en tant que telle.
Principalement, il est difficile pour un chercheur de visiter tous les blogs, ou vice versa. Il peut être le résultat en une même chose, mais les points d'extrémité d'attaque et explication pourrait varier en fonction de la divulgation faite au vendeur nécessaires et leur réponse.

January 3, 2011 at 8:49 AM

[Post a Comment](#)

[Newer Post](#)

[Home](#)

[Older Post](#)

Subscribe to: [Post Comments \(Atom\)](#)

Picture Window theme. Powered by Blogger.

This site uses cookies from Google to deliver its services and to analyse traffic. Your IP address and user agent are shared with Google, together with performance and security metrics, to ensure quality of service, generate usage statistics and to detect and address abuse.

[LEARN MORE](#) [GOT IT](#)